

5.2. KRİPTANALİZ, ŞİFRE KIRMA VE HASH KIRMA

Savunma Derinliği (Defense in Depth) Altyapılarında Kriptografik Kontroller, Algoritma Güvenliği ve Operasyonel Entegrasyon

Yazar: Kıdemli Siber Güvenlik Çözüm Mimarı & SOC Analisti

Standartlar: NIST SP 800-53 Rev.5 / 800-57, ISO/IEC 27001:2022, CIS Controls v8, MITRE ATT&CK, OWASP, RFC 8446 (TLS 1.3)

Yasal Uyum: KVKK Teknik Tedbirler, 5651 Sayılı Kanun, BDDK Siber Güvenlik Yönetmeliği

1. GİRİŞ VE MİMARİ KONUM

Kriptografi, modern kurumsal Savunma Derinliği stratejisinin temel katmanıdır. NIST SP 800-53 Rev. 5 kapsamında SC-8 (Transmission Confidentiality and Integrity), SC-12 (Cryptographic Key Establishment and Management) ve SC-13 (Cryptographic Protection) kontrolleri ile zorunlu hale getirilmiştir. Bu kontroller, veri gizliliği, bütünlüğü, kimlik doğrulama ve reddedilemezlik hizmetlerini sağlar.

Kurumsal Topolojide Konumlandırma:

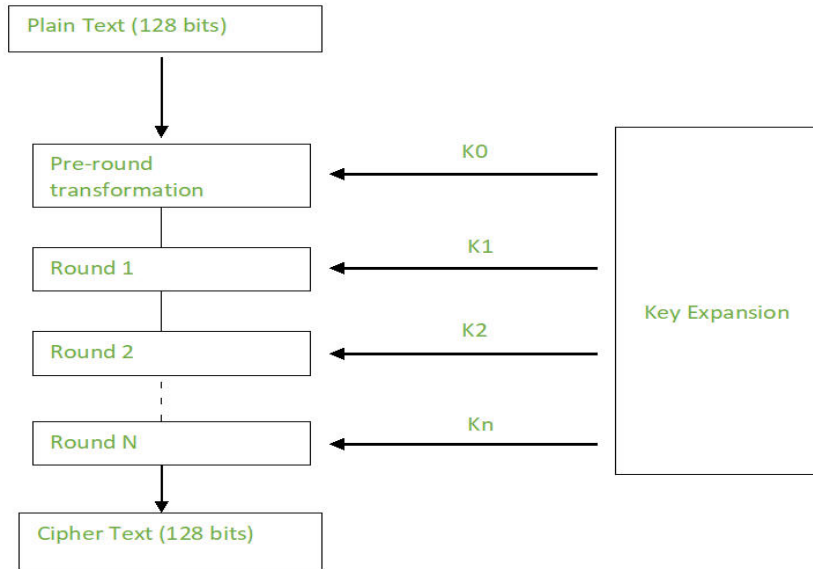
- Perimetre Katmanı (NGFW/Proxy): Palo Alto veya Fortinet gibi cihazlarda SSL/TLS Forward Proxy decryption, X.509 sertifikaları ve PKI ile gerçekleştirilir. Zayıf şifre paketleri (3DES, RC4, MD5 tabanlı) burada engellenir.
- Ağ Katmanı: IPsec VPN (AES-GCM + DH/ECDH), service mesh mTLS (Istio/Linkerd ile RSA/ECC + AES).
- Veri Katmanı: Veritabanı TDE (Transparent Data Encryption - AES-256), disk şifreleme (LUKS/BitLocker), bulut object storage SSE-KMS.
- Uygulama Katmanı: JWT/JWS signing (ES256 veya RS256), API Gateway'de request signing, code signing (sigstore veya Microsoft Authenticode).
- Uç Nokta: Full Disk Encryption + File Integrity Monitoring (Wazuh FIM ile SHA-256).

Bu katmanlı yaklaşım, MITRE ATT&CK; Tactic'lerinden Credential Access (T1552, T1110), Exfiltration (T1041) ve Impact (T1486 - Data Encrypted for Impact) saldırılarına karşı çok katmanlı koruma sağlar. Tek bir katmanın ihlali (örn. CA compromise), diğer katmanlar tarafından izole edilir.

2. SİMETRİK VE ASİMETRİK ALGORİTMALAR

2.1 Simetrik Şifreleme (AES, 3DES)

Simetrik algoritmalar, aynı anahtarın hem şifreleme hem de deşifreleme için kullanıldığı sistemlerdir. Hızlıdır ve büyük veri hacimlerinde tercih edilirler. NIST FIPS 197 ile standartlaştırılan AES (Advanced Encryption Standard), 128/192/256 bit anahtar uzunlukları ile 128 bit blok boyutu kullanır. 2026 itibarıyla AES-256, klasik ve kuantum sonrası (Grover algoritması ile kare kök hızlanması hariç) pratik saldırılara karşı güvenli kabul edilmektedir.



Şekil 1: AES Şifreleme Yapısı ve Anahtar Genişletme (Key Expansion) - NIST SP 800-38 serisi

AES Çalışma Mantiği (Rijndael): 10/12/14 round (128/192/256 bit anahtar için). Her round'da SubBytes (S-box), ShiftRows, MixColumns ve AddRoundKey işlemleri uygulanır. Son round'da MixColumns yoktur. Key Expansion ile anahtar round anahtarlarına genişletilir.

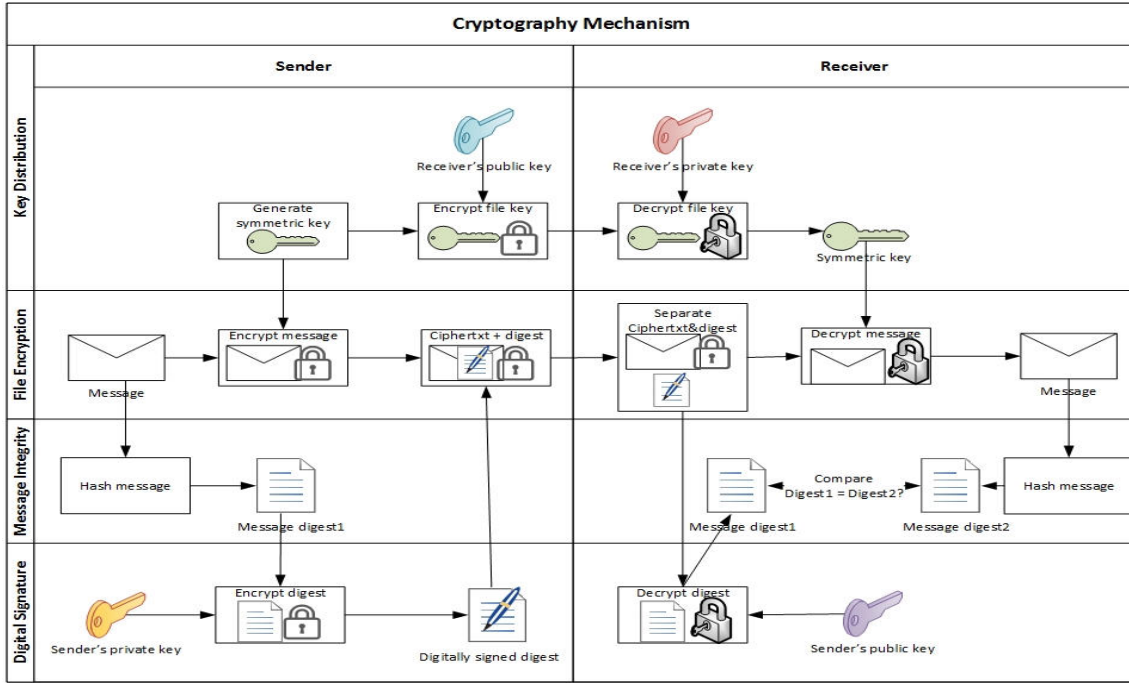
3DES (Triple DES): DES'in 3 kez uygulanması (EDE3 veya EEE3). 168 bit efektif anahtar (112 bit pratik güvenlik). NIST SP 800-131A Rev. 3 (2024 draft) ile 2023 sonrası yeni sistemlerde yasaklanmıştır. Sweet32 saldırısı (2016) ile CBC modunda pratik collision riski gösterilmiştir.

Algoritma Karşılaştırma Tablosu (2026 Güncel)

Algoritma	Anahtar (bit)	Güvenlik Seviyesi	Performans	Durum (NIST/2026)	Önerilen Kullanım
AES-128	128	~128 bit	Yüksek	Onaylı (FIPS 197)	Genel amaçlı, IoT
AES-192	192	~192 bit	Yüksek	Onaylı	Yüksek güvenlik gereksinimleri
AES-256	256	~256 bit	Yüksek	Onaylı (önerilen)	Kritik veriler, BDDK zorunlu
3DES (EDE3)	168 (112 efektif)	~112 bit	Düşük	Kaldırıldı (2023+)	Sadece legacy uyum
ChaCha20	256	~256 bit	Çok Yüksek (ARM)	Onaylı (TLS 1.3)	Mobil/IoT, TLS 1.3 alternatif

2.2 Asimetrik Şifreleme (RSA, ECC, Diffie-Hellman)

Asimetrik (Public-Key) kriptografi, matematiksel olarak ilişkili ama birbirinden hesaplanamaz public/private key çiftleri kullanır. RSA (Rivest-Shamir-Adleman) factoring zorluğuna, ECC (Elliptic Curve Cryptography) ise Elliptic Curve Discrete Logarithm Problem (ECDLP)'ye dayanır. Diffie-Hellman (DH/ECDH) anahtar değişimi için kullanılır.

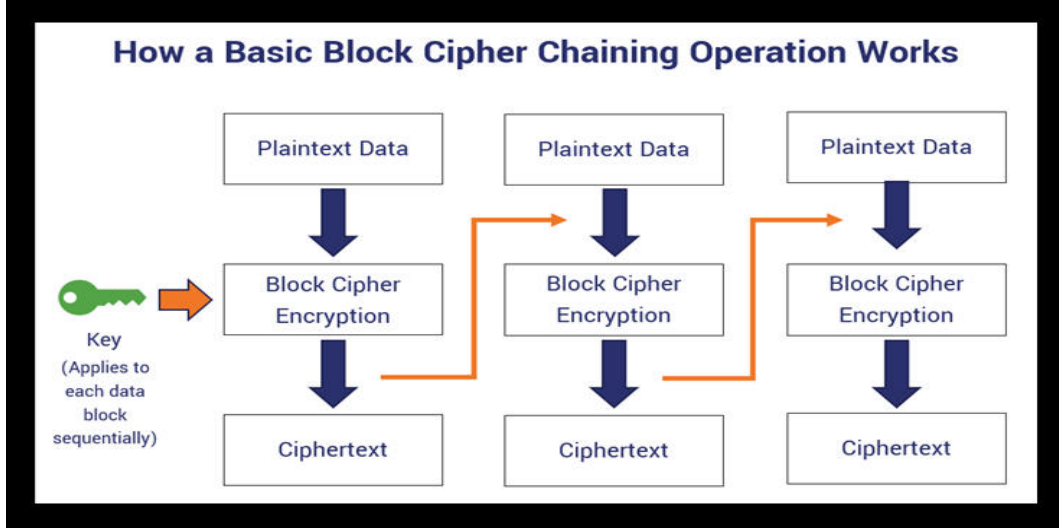


Şekil 2: Simetrik + Asimetrik Hibrit Kriptografi Mekanizması (TLS/Email/File Encryption)

RSA: 2048 bit minimum (2026 için NIST 800-57 Part 1 Rev.5 / upcoming Rev.6 önerisi 3072+ bit veya PQC hibrit). PKCS#1 v1.5 padding Bleichenbacher saldırısına açıktır; OAEP veya PSS kullanılmalıdır. ECC (secp256r1, secp384r1, Curve25519): Daha kısa anahtarlarla eşdeğer güvenlik (256 bit ECC $\approx$ 3072 bit RSA). IoT ve mobil için idealdir. Post-Quantum Tehdit: Shor's algoritması hem RSA hem ECC'yi kırar. NIST 2024'te ML-KEM (Kyber), ML-DSA (Dilithium), SLH-DSA (SPHINCS+) standartlarını yayınlamıştır. 2026+ kurumsal stratejilerde hibrit (klasik + PQC) KEM önerilir.

3. BLOK (BLOCK) VE AKIŞ (STREAM) ŞİFRELEME MANTIĞI

Simetrik şifreleme iki temel modda çalışır: Blok şifreler sabit uzunlukta blokları işler; akış şifreler bit/bit veya byte/byte keystream üretir.



Şekil 3: Blok Şifreleme Zincirleme Mantığı (CBC örneği)

Blok Şifre Modları (NIST SP 800-38 serisi):

- ECB: Aynı plaintext bloğu aynı ciphertext üretir → ASLA KULLANILMAMALIDIR (pattern leakage).
- CBC: IV + zincirleme. Padding (PKCS7) gerekir. Padding Oracle (Lucky13, POODLE) ve BEAST gibi saldırılarla vulnerable. IV rastgele ve unique olmalıdır.
- CTR (Counter): Keystream üretir, parallelization kolay. IV/nonce kritik.
- GCM (Galois/Counter Mode - SP 800-38D): Authenticated Encryption with Associated Data (AEAD). Gizlilik + bütünlük + orijinallik tek adımda. IV 96 bit önerilir. 2026 standardı: AES-GCM veya ChaCha20-Poly1305 (TLS 1.3'de varsayılan).

Akış Şifreleri: RC4 (kırık, yasak), Salsa20/ChaCha20 (modern, yüksek performans). Keystream = $f(\text{key}, \text{nonce})$. Nonce reuse = catastrophic key recovery.

Somut Örnek: OpenSSL ile AES-256-GCM (Güvenli)

```
openssl enc -aes-256-gcm -in plaintext.txt -out ciphertext.bin -K -iv -tag # Veya modern: AES-256-GCM-SIV (SP 800-38G draft, nonce misuse resistant) # Python cryptography kütüphanesi ile: # from cryptography.hazmat.primitives.ciphers.aead import AESGCM # aesgcm = AESGCM(key); ct = aesgcm.encrypt(nonce, data, associated_data)
```

4. HASH FONKSİYONLARI (SHA-256, MD5) VE ÇARPIŞMA ANALİZİ

Kriptografik hash fonksiyonları, sabit uzunlukta çıktı (digest) üretir, tek yönlüdür ve collision/preimage/second-preimage dirençli olmalıdır. MD5 (128 bit) 2004'ten beri pratik collision ataklarına açıktır (Wang & Yu, 2005; 2026'da consumer GPU ile saniyeler). SHA-256 (NIST FIPS 180-4) 256 bit, 128 bit collision direnci ile 2026'da hala güvenli.

Çarpışma (Collision) Saldırıları:

- Birthday Attack: $\sim 2^{(n/2)}$ karmaşıklık (MD5 için $\sim 2^{64}$ teorik, pratik çok daha düşük).
- Flame Malware (2012): Microsoft code signing sertifikası için MD5 collision kullanılarak sahte update imzalandı. Bu, PKI ve code signing'de hash seçiminin kritikliğini gösterdi.

- Length Extension Attack: SHA-1/MD5/SHA-256 (Merkle-Damgård) için secret suffix kullanıldığında (örn. $MAC = H(secret || message)$) vulnerable. HMAC veya SHA-3/Blake2/Blake3 tercih edin.

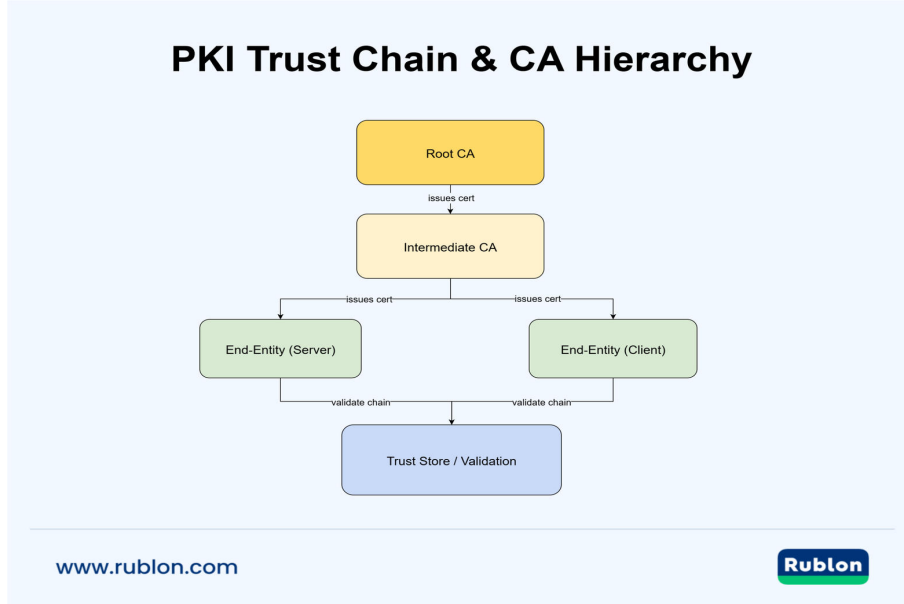
Şifre Hash'leme: Raw SHA-256/MD5 ASLA parola için kullanılmamalıdır. NIST SP 800-63B ve OWASP: Argon2id (memory-hard, side-channel resistant) veya bcrypt/scrypt/PBKDF2 (en az 10^5 iterasyon). Wazuh gibi FIM araçları dosya bütünlüğü için SHA-256 kullanır.

Savunma Örneđi: Wazuh FIM ile SHA-256 Bütünlük İzleme

```
# /var/ossec/etc/ossec.conf içinde syscheck (FIM) yapılandırması /etc,/usr/bin,/var/www /critical/configs # Log örneđi:  
"File integrity monitoring. File '/etc/passwd' was modified. SHA256: abc123..."
```

5. AÇIK ANAHTAR ALTYAPISI (PKI) VE DİJİTAL SERTİFİKALAR

PKI, X.509 v3 sertifikaları (RFC 5280), Certificate Authority (CA), Registration Authority (RA), Certificate Revocation List (CRL) ve Online Certificate Status Protocol (OCSP) bileşenlerinden oluşur. Kurumsal PKI, internal CA (Active Directory Certificate Services, EJBCA, Dogtag) ile device authentication, mTLS, code signing, email signing (S/MIME) ve VPN için kullanılır.



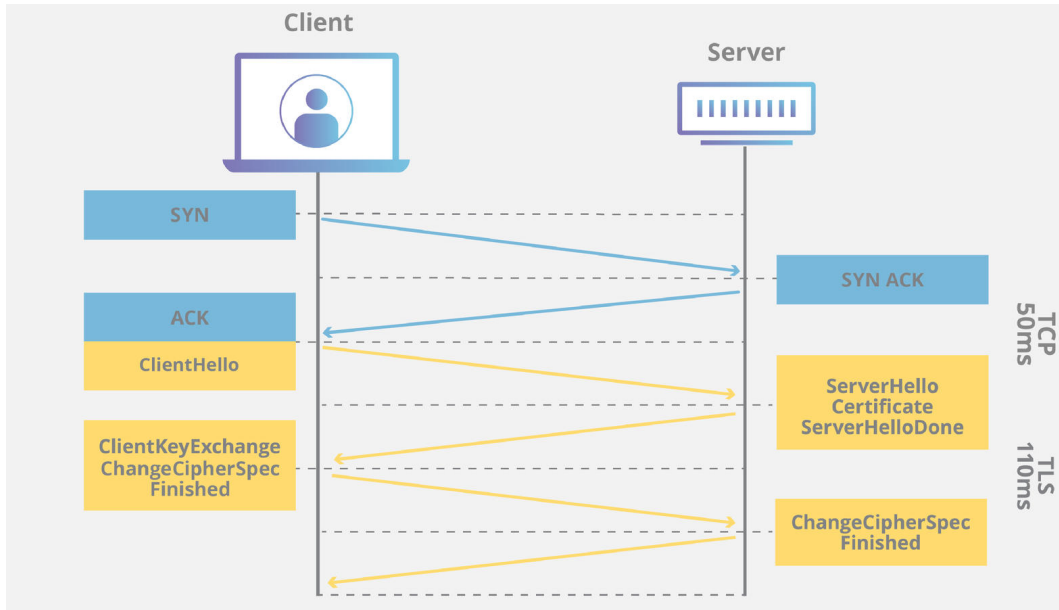
Şekil 4: PKI Trust Chain ve CA Hiyerarşisi (Root → Intermediate → End-Entity)

Saldırı Vektörleri (Ofansif):

- CA Compromise: DigiNotar (2011), Comodo (2011) gibi olaylarda sahte sertifikalar ile MitM saldırısı. Saldırgan Google.com için geçerli sertifika aldı.
- Rogue CA / Self-Signed in Trust Store: Sennheiser gibi yazılımlar trust store'a kendi root CA'sını ekleyip private key'i embed ederse tam MitM mümkün.
- Certificate Pinning Bypass / HPKP Kaldırılması: Dynamic pinning veya Expect-CT ile mitigasyon.
- OCSP Stapling eksikliği + CRL poisoning veya soft-fail validation.

Savunma (Defansif) ve En İyi Pratikler:

- Crypto-Agility: Birden fazla CA ile ilişki (Palo Alto GlobalProtect, Venafi Enterprise Key & Certificate Management). CA compromise'te saatler içinde rotation.
- Private Key Protection: HSM (FIPS 140-2/3 Level 3+), TPM 2.0, veya cloud KMS (AWS KMS, Azure Key Vault) ile never exportable.
- Certificate Transparency (CT) Logs: RFC 6962. Tüm sertifikalar public CT log'lara yazılır; mis-issuance tespit edilir (Chrome, Safari zorunlu).
- mTLS + Certificate Pinning / HPKP (legacy) + Expect-CT header.
- OCSP Must-Staple + Short-lived certificates (Let's Encrypt model, 90 gün).
- NIST SP 800-57 Key Management: Anahtar lifecycle (generation → distribution → storage → rotation → destruction). 2-3 yıl rotation önerisi kritik anahtarlar için.



Şekil 5: TLS 1.3 Handshake - Asimetrik (Certificate + Key Exchange) + Simetrik (Session Keys) Hibrit

6. ULUSLARARASI STANDARTLAR VE TÜRKİYE YASAL ENTEGRASYONU

NIST SP 800-53 Rev. 5 (2025 Update 5.2.0): SC-12, SC-13, SC-8, IA-5, AU-9 (audit log integrity via hashing), CP-9/10 (backup encryption). SP 800-57 Part 1 Rev. 5 (Rev. 6 draft 2025) anahtar yönetimi lifecycle'ını tanımlar.

ISO/IEC 27001:2022 A.10 Cryptography: Politika, anahtar yönetimi, kriptoloji kontrolü.

CIS Controls v8: Control 3 (Data Protection) - encrypt sensitive data at rest/transit; Control 16 (Account Management) - strong authenticators.

Türkiye Mevzuatı:

- KVKK Kişisel Veri Güvenliği Rehberi (Teknik Tedbirler): Kişisel verilerin kriptografik yöntemlerle şifrelenmesi zorunlu (bulut için ayrı anahtarlar, ilişki bitince anahtar imhası). AES, RSA vb. uluslararası kabul gören algoritmalar önerilir.
- 5651 Sayılı Kanun (İnternet Ortamında Yapılan Yayınların Düzenlenmesi): Erişim sağlayıcıları trafik loglarını (IP, timestamp, MAC, hizmet türü) elektronik ortamda 1-2 yıl saklamakla yükümlü. Günlük HASH + zaman damgası ile bütünlük ve değiştirilemezlik sağlanmalı (SHA-256 önerilir). Loglar imzalanmalı.
- BDDK Bankaların Bilgi Sistemleri ve Elektronik Bankacılık Hizmetleri Hakkında Yönetmelik (Siber Güvenlik): Kritik veriler için AES-256 zorunlu, TLS 1.2 minimum (1.3 önerilir), ECC kabul edilir. Anahtarlar fiziksel olarak ayrı ortamlarda (HSM), versiyon kontrolü ve kriptoloji envanteri zorunlu.

7. SONUÇ VE MÜHENDİSLİK ÖNERİLERİ

Kriptanaliz ve şifre kırma vektörleri, Savunma Derinliği'nde en kritik ve kalıcı risk katmanıdır. 2026 itibarıyla:

- Simetrik: AES-256-GCM veya ChaCha20-Poly1305 zorunlu; 3DES/MD5/RC4 tamamen terk edin.
- Asimetrik: RSA ≥ 3072 bit veya ECC P-256/384; PQC hibrit geçiş planı (NIST ML-KEM) 2027-2030 için hazırla.
- Hash: Güvenlik amaçlı SHA-256/SHA-3; parolalar Argon2id; FIM'de SHA-256.
- PKI: Internal PKI + HSM + CT + crypto-agility + short-lived certs. CA compromise senaryosu için runbook hazır tutun.

Operasyonel Entegrasyon: Wazuh (FIM + log integrity), Palo Alto/Fortinet (cipher enforcement +

decryption inspection), OpenSSL testleri, SIEM'de (Wazuh/ELK) weak crypto kullanımı alert'leri. KVKK/5651/BDDK loglama + şifreleme uyumunu otomatik denetleyin (CIS-CAT veya custom script).

Bu yaklaşım, hem ofansif (saldırganın factoring, collision, padding oracle, CA compromise sömürüsü) hem defansif (mavi takımın detection, prevention, response) boyutları ile dengeli bir Savunma Derinliđi sağlar ve uluslararası standartlar ile ulusal yasal yükümlölükleri eksiksiz karşılar.

Bu belge, NIST, ISO, CIS, MITRE ATT&CK; RFC standartları, üretici dokümantasyonları (Palo Alto, Fortinet, Wazuh) ve Türkiye yasal mevzuatları (KVKK, 5651, BDDK) temel alınarak Deep Research metodolojisiyle hazırlanmıştır. Güncel revizyonlar için NIST CSRC ve resmi gazete takip edilmelidir.